



PHISHING AWARENESS TRAINING

Recognize. Resist. Report.

Cybersecurity Awareness Project | Task 2

Phishing, fake websites, social engineering, best practices, case studies and quizzes

October 2026

Contents

1	Introduction and Learning Objectives
2	What Is Phishing? Types of Attacks
3	Recognizing Phishing Emails
4	Spotting Fake Websites
5	Social Engineering Tactics
6	Real-World Case Studies
7	Best Practices to Stay Safe
8	What To Do If You Fall for a Phish
9	Interactive Quiz 1: Knowledge Check
10	Interactive Quiz 2: Real or Phish?
11	Answer Key and Explanations
12	Quick Reference Checklist, Glossary and Resources

How to use this module

Read sections 1-8, then test yourself with the two quizzes. Cover the answer key (Section 11) until you have finished. Aim for at least 80%. Repeat the quizzes after a few weeks, as awareness fades without practice.

SECTION 1

Introduction and Learning Objectives

Phishing is one of the most common ways attackers break into organizations and personal accounts. Instead of attacking software, the attacker attacks **people**: a convincing message persuades the victim to click a link, open a file, share a password or send money. Because it exploits trust and urgency rather than technical flaws, even well-protected systems can be compromised by a single careless click.

Why it matters

- It is low-cost for attackers and easy to scale: one message can be sent to millions of people.
- It is the starting point for many other incidents: stolen credentials, ransomware, business email compromise and data breaches.
- AI tools now help attackers write fluent, error-free messages, so the old advice of 'look for spelling mistakes' is no longer enough.
- Anyone can be targeted: employees, students, executives, and families.

Learning objectives

After completing this module you will be able to:

- Define phishing and describe its main variants (email, spear phishing, whaling, smishing, vishing, QR phishing, clone phishing).
- Identify the warning signs of phishing emails and fake websites.
- Explain the psychological tactics behind social engineering.
- Describe real incidents and what they teach us.
- Apply practical habits (verify, pause, report) and use tools such as MFA and password managers.
- Respond correctly if you believe you have been phished.

The golden rule

Stop. Think. Verify. Any message that creates urgency, asks for sensitive information, or requests money or a login deserves a pause and verification through a separate, trusted channel.

SECTION 2

What Is Phishing? Types of Attacks

Phishing is a form of social engineering in which an attacker impersonates a trusted person, brand or authority to trick the victim into revealing information, installing malware or taking a harmful action. The name is a play on 'fishing': the message is the bait and the victim is the catch.

Type	How it works	Example
Email phishing	Mass emails impersonating banks, delivery firms, or online services.	'Your account is suspended - verify now.'
Spear phishing	Targeted at one person using researched details (name, role, colleagues).	A fake message from your manager mentioning a real project.
Whaling	Spear phishing aimed at senior executives or finance leaders.	A fake legal notice sent to a CEO.
Business Email Compromise (BEC)	Attacker poses as an executive or supplier to redirect payments.	'We changed bank accounts. Pay this invoice to the new one.'
Smishing	Phishing via SMS or messaging apps.	'Package held - pay a small fee at this link.'
Vishing	Phone calls, sometimes with cloned or spoofed voices.	A caller claims to be 'bank fraud department'.
Quishing	Malicious QR codes that lead to fake sites.	A QR code sticker pasted over a parking payment code.
Clone phishing	A genuine earlier email is copied and resent with a malicious link or file.	'Resending the document with the updated link.'
Angler / social media phishing	Fake support accounts or direct messages on social platforms.	A fake 'support' account replying to your complaint.

The typical attack flow

1. Research	2. Craft the lure	3. Deliver	4. Victim acts	5. Exploit
Attacker gathers names, roles and brands from public sources.	Builds a believable message or fake page.	Sends by email, SMS, call or social media.	Clicks, enters credentials, opens file or pays.	Takes over accounts, steals data, or installs malware.

SECTION 3

Recognizing Phishing Emails

Below is a typical phishing email. Each red number marks a warning sign explained underneath.
(This is a fictional example created for training.)

From: Secure Team <support@paypa1-security.com> [1]
To: undisclosed-recipients [2]
Subject: URGENT!! Your account will be CLOSED in 24 hours [3]
Dear Customer, [4] We detected unusual activity on your account. To avoid permanent suspension, you must confirm your identity immediately. [3] Click here to verify your account [5] (link actually points to http://paypa1-login.example-verify.top/signin) Attachment: Account_Form.html [6] Failure to respond will result in loss of funds and legal action. [7]

#	Red flag	Explanation
1	Look-alike sender domain	'paypa1' uses the digit 1 instead of the letter l. Always read the domain after the @ symbol carefully. The display name can be faked; the address cannot be trusted just because the name looks right.
2	Generic recipient	Mass campaigns often hide or fail to personalize recipients.
3	Urgency and threats	Deadlines such as '24 hours' and threats of closure pressure you to act before thinking.
4	Impersonal greeting	Real providers usually address you by name, though spear phishing can also include your name.
5	Mismatched link	Hover over (or long-press) a link to preview the real destination. It does not match the brand's official domain.
6	Unexpected attachment	HTML, ZIP, ISO, or Office files with macros are common malware or credential-harvesting carriers.
7	Fear of consequences	Legitimate companies rarely threaten legal action by email without prior notices.

Other warning signs

- Requests for passwords, one-time codes (OTP), PINs, card numbers or other sensitive data. Legitimate organizations will not ask for these by email or phone.
- Unusual requests from known people: gift cards, urgent wire transfers, changes to bank details, or 'keep this confidential'.
- Too good to be true: prizes, refunds, or unexpected job offers with very high pay.
- Poor grammar can still be a clue, but **do not rely on it**: modern phishing often looks polished.

SECTION 4

Spotting Fake Websites

Phishing links usually lead to a page that looks identical to a real login or payment page. Anything you type goes straight to the attacker. Checking the address bar is the most important habit.

URL tricks attackers use

Technique	Fake example	What is happening
Typosquatting	amazom.com	A one-letter change in a real brand name.
Homoglyphs	rnicrosoft.com	'rn' looks like 'm'. Some attacks use look-alike characters from other alphabets.
Brand in subdomain	bank.com.secure-login.net	The real domain is the part just before the final extension: here it is secure-login.net , not bank.com.
Extra words	yourbank-support-verify.com	Real brands rarely use hyphenated 'verify' or 'secure' domains for sign-in.
Unusual extension	yourbank.top / .xyz	Cheap domains are heavily abused, though a normal-looking extension is not proof of safety.
URL shorteners	short.link/x7Gh2	Hide the true destination. Use a link-preview tool or avoid clicking.
'@' or IP in URL	http://bank.com@203.0.113.9/	Everything before the '@' is ignored by browsers; the real host is after it.

Fake website checklist

- **Domain:** Is the domain exactly what you expect? Type it yourself or use a saved bookmark instead of following links.
- **HTTPS padlock:** A padlock only means the connection is encrypted. Phishing sites also use HTTPS, so it does **not** prove the site is genuine.
- **Unexpected login prompts:** Did you arrive on a sign-in page from an email, SMS, or pop-up you did not request?
- **Odd design:** Low-resolution logos, broken layouts, missing pages (privacy policy, contact), or links that go nowhere.
- **Excess requests:** Pages asking for card number, PIN, OTP and date of birth together are suspicious.
- **Pop-ups and fake alerts:** 'Your device is infected - call this number' is a scam. Close the tab.
- **Browser warnings:** Take Safe Browsing or antivirus warnings seriously.

Pro tip: password managers help

A password manager only auto-fills credentials on the exact domain where they were saved. If it refuses to fill in a login that 'looks right', that is a strong signal that the site is fake.

SECTION 5

Social Engineering Tactics

Social engineering manipulates human psychology to bypass security controls. Attackers rely on predictable emotional triggers. Knowing these triggers helps you notice when someone is trying to hurry you.

Tactic	What the attacker does	Typical wording	Defense
Urgency / scarcity	Creates a deadline so you skip checks.	'Act within 1 hour or lose access.'	Slow down. Real issues can be verified through official channels.
Authority	Pretends to be a boss, police, tax office, or IT.	'This is the CEO. I need this now.'	Verify by calling a known number. Authority does not exempt anyone from process.
Fear	Threatens loss, penalty, or embarrassment.	'Your account will be closed and reported.'	Fear is a cue to verify, not to comply.
Curiosity / greed	Offers prizes, gossip, or unexpected files.	'You won!' / 'Salary list attached.'	Unexpected offers deserve suspicion.
Helpfulness / trust	Exploits kindness or teamwork.	'Can you quickly help me with a gift card purchase?'	Confirm unusual requests in person or by a different channel.
Pretexting	Builds a believable story and fake identity.	'I'm from IT doing a security audit.'	Check identity with the real IT help desk.
Reciprocity / familiarity	Does you a small favor, then asks for one.	'I fixed your ticket; can you confirm your login?'	Never share credentials, whatever favor was done.
Baiting / USB drops	Leaves infected USB drives or offers free downloads.	A USB labeled 'Salaries 2026'.	Never plug in unknown devices.
MFA fatigue	Spams approval prompts until the victim taps 'Approve'.	A flood of login approvals at night.	Deny unexpected prompts and report them immediately.

AI and deepfakes

Attackers can now clone voices and faces from short public samples. A call or video that sounds exactly like your boss is not proof of identity. For payments, credentials or sensitive data, use a second channel (call back a known number) or an agreed code word.

SECTION 6

Real-World Case Studies

These publicly reported incidents show that phishing and social engineering affect even large, security-aware organizations.

Case 1: Fake invoices to Google and Facebook (2013-2015)

What happened: A Lithuanian fraudster, Evaldas Rimasauskas, impersonated a genuine hardware supplier and sent invoices, with forged contracts and letterheads, to employees of large technology companies. Payments totalling over US\$100 million were sent to accounts he controlled. He was later extradited to the US, pleaded guilty and was sentenced to prison.

Lesson: Verify payment-detail changes and invoices through independent channels, and enforce dual approval for large transfers.

Case 2: The 2016 Podesta email compromise

What happened: A fake Google security alert asked the chairman of a US presidential campaign to change his password through a shortened link. The page captured his credentials and thousands of emails were later leaked.

Lesson: Never use links in security alerts; go to the service directly. Use multi-factor authentication.

Case 3: RSA Security breach (2011)

What happened: Employees received spear-phishing emails with an Excel attachment titled '2011 Recruitment plan'. Opening it exploited a vulnerability and installed a remote-access tool, leading to the theft of information related to the company's SecurID products.

Lesson: Even security vendors are targeted. Patch promptly, and treat unexpected attachments with caution.

Case 4: Twitter account takeover (2020)

What happened: Attackers used phone-based social engineering (vishing) against Twitter employees to obtain credentials for internal tools. They then took over high-profile accounts and promoted a cryptocurrency scam.

Lesson: Staff need training on phone-based pretexting, and internal tools need strong access controls.

Case 5: Uber breach via MFA fatigue (2022)

What happened: An attacker obtained a contractor's credentials, repeatedly triggered multi-factor authentication requests and then contacted the contractor on a messaging app pretending to be IT support, persuading them to approve a prompt.

Lesson: Use phishing-resistant MFA (security keys or passkeys), and never approve prompts you did not initiate.

Case 6: MGM Resorts help-desk attack (2023)

What happened: The attackers reportedly gathered employee details from public sources and phoned the IT help desk pretending to be an employee, obtaining access that led to major service disruption.

Lesson: Strengthen identity verification for password and MFA resets.

Case summaries are simplified from public reporting and court records; details may differ across sources.

SECTION 7

Best Practices to Stay Safe

Individual habits

- **Pause before you click.** Slow down on anything urgent, emotional or unexpected.
- **Verify through a second channel.** Call the person or organization using a number you already know, not one in the message.
- **Go directly to the source.** Type the website address or use a bookmark rather than clicking links in messages.
- **Inspect links.** Hover over links (or long-press on mobile) and read the full domain before clicking.
- **Never share OTPs, PINs or passwords.** No genuine bank, employer or support team will ask for them.
- **Be careful with attachments.** Open only files you expect; preview documents with macros disabled.
- **Limit what you share publicly.** Job titles, travel plans and org charts help attackers craft convincing lures.

Technical protections

- **Enable multi-factor authentication (MFA)** everywhere. Prefer passkeys or hardware security keys, which resist phishing better than SMS codes.
- **Use a password manager** with unique, long passwords for every account.
- **Keep software updated:** operating system, browser, and apps.
- **Use email filtering and browser protection** (Safe Browsing, reputable endpoint security).
- **Back up important data** offline or in a separate cloud location to recover from ransomware.
- **Email authentication** (SPF, DKIM, DMARC) for organizations to reduce spoofing of their domains.

Organizational measures

- Regular awareness training and simulated phishing exercises, with a positive, non-punitive culture.
- A one-click '**Report phishing**' button and a clear reporting process.
- Dual approval and call-back verification for payment changes and large transfers.
- Least-privilege access and strong identity checks for help-desk resets.
- An incident response plan that is practiced, not just written.

Remember: the 3 R's

Recognize the warning signs | **Resist** the urge to act in a hurry | **Report** it, even if you are unsure or already clicked.

SECTION 8

What To Do If You Fall for a Phish

Mistakes happen. Speed matters far more than embarrassment: the sooner you act, the more damage can be limited.

Step	Action
1. Disconnect	If you opened a suspicious file or installed something, disconnect the device from the network (Wi-Fi/cable) but do not power-off until advised by IT.
2. Change passwords	Change the password for the affected account from a clean device, and anywhere you reused it. Enable MFA.
3. Revoke sessions	Sign out of all devices, review recent logins, forwarding rules and connected apps.
4. Report	Notify your IT or security team immediately. For personal accounts, report to the service provider. Forward phishing to the relevant authority.
5. Contact your bank	If financial details or payments were involved, call the bank right away to block cards and attempt to recall transfers.
6. Scan your device	Run a full antivirus scan; let IT inspect or reimage the device if malware is suspected.
7. Watch for fallout	Monitor accounts and credit activity for suspicious activity; be alert to follow-up scams.
8. Learn	Share the details with your team (without blame) so others can recognize the same lure.

Where to report (India)

National Cyber Crime Reporting Portal: cybercrime.gov.in | **Helpline:** 1930 for financial cyber fraud | **CERT-In:** incident@cert-in.org.in. Elsewhere, use your national cybercrime or consumer-protection authority. Check these contacts on the official sites before use, as they can change.

SECTION 9

Interactive Quiz 1: Knowledge Check

Choose the best answer for each question. Write your answers in the score box at the end. Answers are in Section 11.

Q1. Which of the following is the strongest sign that an email may be phishing?

- ☐ A. It contains a company logo
- ☐ B. It demands immediate action and asks you to log in through a link
- ☐ C. It was sent on a weekend
- ☐ D. It is addressed to several people

Q2. What is spear phishing?

- ☐ A. Phishing sent to millions of random users
- ☐ B. A targeted phishing attack tailored to a specific person or group
- ☐ C. Phishing only by phone
- ☐ D. A virus that spreads by USB

Q3. The padlock icon in your browser means:

- ☐ A. The website is definitely safe and genuine
- ☐ B. The connection is encrypted, but the site could still be fake
- ☐ C. The site has been approved by the government
- ☐ D. The site cannot contain malware

Q4. Which URL is most likely to be fake for a bank called 'safebank.com'?

- ☐ A. <https://www.safebank.com/login>
- ☐ B. <https://online.safebank.com>
- ☐ C. <https://safebank.com.account-verify.net/login>
- ☐ D. <https://safebank.com/contact>

Q5. A caller says they are from your bank's fraud team and asks for the OTP you just received. You should:

- ☐ A. Share it to stop the fraud
- ☐ B. Share only the last 3 digits
- ☐ C. Hang up and call the bank on its official number
- ☐ D. Ask them to send it by email

Q6. Your 'CEO' emails asking you to urgently buy gift cards and keep it confidential. The best response is:

- ☐ A. Buy them quickly, since the CEO asked
- ☐ B. Reply asking for more details
- ☐ C. Verify with the CEO via a known phone number or in person, and report the email
- ☐ D. Forward the email to colleagues for opinions

Q7. Which type of MFA is generally the most resistant to phishing?

- ☐ A. SMS codes
- ☐ B. Security keys or passkeys
- ☐ C. Security questions
- ☐ D. Email codes

Q8. You receive repeated MFA approval prompts at night that you did not trigger. You should:

- ☐ A. Approve one to make them stop
- ☐ B. Ignore them
- ☐ C. Deny them, change your password and report it
- ☐ D. Disable MFA

Q9. Which is an example of baiting?

- ☐ A. A text claiming a package is held
- ☐ B. A USB drive labeled 'Salary 2026' left in a parking lot
- ☐ C. A call from a fake tax officer
- ☐ D. An email greeting you by name

Q10. If you clicked a phishing link and entered your password, the first thing to do is:

- ☐ A. Wait to see if anything happens
- ☐ B. Delete the email and forget about it
- ☐ C. Change the password from a safe device, enable MFA, and report it
- ☐ D. Reply to the sender

Your answers	Q1: ____	Q2: ____	Q3: ____	Q4: ____	Q5: ____
	Q6: ____	Q7: ____	Q8: ____	Q9: ____	Q10: ____

SECTION 10

Interactive Quiz 2: Real or Phish?

Read each scenario and decide whether it is **LEGITIMATE** or **PHISHING**, then note the clues that led to your decision. All examples are fictional.

Scenario 1	Email from <code>alerts@netflix-billing.com</code> : 'Payment failed. Update your card within 12 hours or your membership will be cancelled.' Button: <i>Update Payment</i> . () Legitimate () Phishing Clues: _____
Scenario 2	SMS: 'Your parcel is held at the depot. Pay a Rs. 25 redelivery fee: <code>http://track-parcel.example-delivery.xyz</code> '. You were not expecting a parcel. () Legitimate () Phishing Clues: _____
Scenario 3	You open your bank's app yourself, and a notice in the app says that new branch hours start next month. No links or requests for information. () Legitimate () Phishing Clues: _____
Scenario 4	Email from a colleague's real address, which was compromised: 'Are you at your desk? I need a quick favor. Reply ASAP.' Later: 'Buy 5 gift cards, I will refund you.' () Legitimate () Phishing Clues: _____
Scenario 5	Email from your IT department: 'Password expires today. Log in at <code>https://helpdesk.yourcompany.com.internal-reset.co</code> to avoid lockout.' () Legitimate () Phishing Clues: _____
Scenario 6	You request a password reset on a website you use. A minute later you receive an email with a reset link, and the domain exactly matches the official site. () Legitimate () Phishing Clues: _____

Bonus: Design your own phishing-awareness poster

Create a one-page poster that teaches colleagues three red flags and one action to take. Use plain language, an eye-catching slogan, and a clear 'Report' contact.

SECTION 11

Answer Key and Explanations

Quiz 1

Q	Answer	Why
1	B	Urgency combined with a request to log in through a link is the classic phishing pattern.
2	B	Spear phishing uses personal details to target a specific individual or group.
3	B	HTTPS only encrypts traffic. Attackers can obtain certificates for fake sites too.
4	C	The real domain is 'account-verify.net'; 'safebank.com' is only a subdomain label.
5	C	Never share OTPs. End the call and contact the bank using the number on your card or official website.
6	C	Gift-card requests with secrecy are a classic BEC scam. Verify using another channel and report.
7	B	Security keys and passkeys are bound to the real site, so a fake site cannot capture them in the usual way.
8	C	Unrequested prompts indicate that someone has your password. Deny, reset it and report.
9	B	Baiting uses physical or digital 'bait' such as infected USB drives to lure victims.
10	C	Act fast: change password from a clean device, enable MFA, revoke sessions and report.

Quiz 2

#	Verdict	Explanation
1	PHISHING	Look-alike domain ('netflix'), urgency, and a payment link. Open the official app or site yourself instead.
2	PHISHING	Unexpected parcel, small fee, odd domain extension. Real couriers have official apps and tracking pages.
3	LEGITIMATE	You initiated the contact through the official app, and there is no link or request for data.
4	PHISHING	A compromised real account can still send scams. The gift-card request, urgency and secrecy are the clues. Call to confirm.
5	PHISHING	The real domain is 'internal-reset.co'. The company name is just a subdomain. Check with IT using a known channel.
6	LEGITIMATE	You triggered the request, the timing fits, and the domain exactly matches. For extra safety, type the site address yourself rather than clicking.

Total score (Quiz 1 + Quiz 2 = 16 points)	Result
14-16	Phish-proof. Share your knowledge with others.
10-13	Good. Review the sections you missed.
0-9	Needs practice. Re-read Sections 3-5 and retake the quizzes.

SECTION 12

Quick Reference Checklist, Glossary and Resources

Before you click or reply, ask yourself:

[]	Was I expecting this message?
[]	Do I recognize the sender, and is the full address correct?
[]	Is it creating urgency, fear or excitement?
[]	Does the link's real destination match the organization?
[]	Is it asking for passwords, OTPs, money or personal data?
[]	Can I confirm this through a different, trusted channel?
[]	If unsure, have I reported it instead of acting?

Glossary

BEC	Business Email Compromise: impersonating executives or vendors to redirect money.
MFA	Multi-factor authentication: requiring more than a password to sign in.
OTP	One-time password or code sent or generated for a single login.
Passkey	A phishing-resistant sign-in method that uses cryptographic keys instead of passwords.
Pretexting	Inventing a believable scenario to obtain information.
Spoofing	Faking a sender's name, number or address.
SPF/DKIM/DMARC	Email authentication standards that help receivers detect forged sender domains.
Typosquatting	Registering misspelled versions of real domains.

Further resources

- Anti-Phishing Working Group (APWG): apwg.org
- CISA - Avoiding Social Engineering and Phishing Attacks: cisa.gov
- National Cyber Crime Reporting Portal (India): cybercrime.gov.in
- Google Phishing Quiz and similar practice tools (search for current versions)
- Have I Been Pwned: haveibeenpwned.com, to check whether your email appears in breaches

Conclusion

Phishing succeeds when people are rushed, distracted or trusting. Technology helps, but **informed, calm and questioning people** are the strongest defense. Verify before you trust, report even when unsure, and help others learn.